



Lab 5 — Run a NIST AI RMF Gap Assessment

Topic 02: Building an AI Governance Framework: Policies, Roles and Risk Ownership

Objective: Evaluate an organisation against the NIST AI RMF GOVERN, MAP, MEASURE and MANAGE functions and produce a prioritised gap register.

Goal: NovaBank has an information-security programme but no AI-specific governance. You will assess the bank against the NIST AI RMF using the supplied evidence pack — policy extracts, meeting minutes and interview notes — scoring each subcategory and producing a gap register that drives the rest of the course.

What you'll build: A completed NIST AI RMF gap assessment across 16 subcategories, each scored with evidence, plus a top-10 prioritised gap register.

Tools and data: Evidence pack (policy-extracts.md, governance-interviews.md, existing-controls.csv), RMF assessment worksheet

Data files in this lab

- data/existing-controls.csv
- data/governance-interviews.md
- data/policy-extracts.md
- data/rmf-assessment-worksheet.csv

Step-by-step

1. Open the evidence pack in labs/lab-05-nist-rmf-gap/data/. Read policy-extracts.md and governance-interviews.md fully before scoring anything — score on evidence, not impression.
2. Score the GOVERN function. Assess GOVERN 1.1 legal and regulatory requirements, 1.2 trustworthiness in policy, 1.6 AI system inventory, 1.7 decommissioning, 2.1 roles and responsibilities, 2.3 executive accountability and 6.1 third-party AI risk.
3. Use a four-point scale for every subcategory: 0 Not in place, 1 Ad hoc, 2 Defined but not consistently applied, 3 Managed with evidence. Record the specific evidence line that justifies each score.
4. Score the MAP function: MAP 1.1 intended purpose and context, 1.5 risk tolerances, 2.3 TEVV considerations, and whether risk is framed per system or only at portfolio level.

5. Score the MEASURE function: MEASURE 1.1 metrics selected, 1.3 independent internal review, and whether any AI system is currently tested for bias, robustness or jailbreak resistance.
6. Score the MANAGE function: MANAGE 1.2 risk prioritisation, 1.4 residual risk documented and accepted by a named owner, and 4.1 post-deployment monitoring.
7. Calculate the average score per function and identify which function is weakest. In most organisations with mature InfoSec, MEASURE scores lowest — check whether that holds here.
8. Build the gap register: for each gap record the subcategory, current score, target score, business risk if unaddressed, remediation action, owner and effort (S/M/L).
9. Prioritise the top ten gaps by risk reduction per unit of effort, not by score alone. A cheap fix closing a High risk outranks an expensive fix closing a Medium one.

Test it

Every subcategory score cites a specific line of evidence from the pack. Your gap register's top three items are all High-risk, and you can defend why a lower-scoring subcategory did not make the top ten.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.